مشروع أمني عملي | SOC & SIEM Portfolio

نظام الاستجابة التلقائية ورصد طلبات DNS عبر Splunk

إعداد المهندس: عبدالله فيصل راجح | تخصص: الأمن السيبراني ومراقبة التهديدات

1. الملخص التنفيذي للمشروع (Executive Summary)

يمثل هذا المشروع حلاً أمنياً متكاملاً يجمع بين **الإنفاذ التلقائي لسياسات الأمان (Automated Endpoint Policy Enforcement)** على أجهزة المشتركين، و**تحليل السجلات المتقدم (SIEM Analysis)** باستخدام أداة Splunk. يهدف المشروع إلى الحد من الخروقات الأمنية، ومنع الوصول للمواقع والمحتوى المحظور، واستخراج أسماء النطاقات (DNS Domain Names) التي يستعلم عنها المستخدمون مع فلترة الضوضاء والأنشطة المعتادة.

2. الجزء الأول: سكربت الاستجابة المباشرة (Endpoint Enforcement Script)

سكربت بلغة Windows Batch تُجرى معالجته بشكل مستمر على جهاز المستخدم لرصد أي نشاط يخالف سياسة الأمان الخاصة بالشركة وإيقافه فوراً.

```
@echo off chcp 65001 >nul :LOOP tasklist /V /FI "STATUS eq running" | findstr /I "youtube facebook netflix" >nul if %ERRORLEVEL% EQU 0 ( taskkill /F /IM msedge.exe /T >nul 2>&1 taskkill /F /IM chrome.exe /T >nul 2>&1 taskkill /F /IM firefox.exe /T >nul 2>&1 msg * "تنبيه أمني: لقد حاولت الوصول إلى محتوى محظور هكر اختراق يوتيوب فيسبوك نتفليكس..." ) timeout /t 1 /nobreak >nul goto LOOP
```

آلية عمل السكربت وتفسيره التقني:

الأمر / العنصر	الوظيفة والتحليل الأمني
chcp 65001	ضبط ترميز موجه الأوامر لدعم اللغة العربية (UTF-8) لضمان مطابقة الكلمات المفتاحية العربية.
tasklist /V /FI ...	مراقبة قائمة العمليات النشطة والعناوين المعروضة شريط المتصفح لكشف الكلمات المحظورة.
taskkill /F /IM ...	إنهاء فورسي (Forced Termination) لكافة المتصفحات (Edge, Chrome, Firefox) لمنع الخرق فوراً.
msg * "..."	إظهار نافذة تنبيه للمستخدم لإبلاغه بمخالفة السياسة الأمنية للمؤسسة.

3. الجزء الثاني: استعلام التحليل والرصد في Splunk (SPL Query)

يقوم هذا الاستعلام بتحليل سجلات أحداث Windows DNS (EventCode 3008) داخل منصة Splunk لكشف وتتبع النطاقات التي يحاول المستخدمون الاتصال بها بعد استخراجها وتصفيتها.

```
index="vpn3" source="*DNS-Client/Operational" EventCode=3008 | rex field=_raw "th
e name (?<DomainName>[^,]+)" | where isnotnull(DomainName) | eval DomainName=lower(Doma
inName) | search NOT DomainName IN ("wpad", "*.microsoft.com", "*.msn.com", "*.t-msedg
e.net", "*.windowsupdate.com", "*.windows.com", "*.live.com", "*.msftncsi.com", "*.sfx.
ms", "*.delivery.mp.microsoft.com", "dns.msftncsi.com") | dedup host, DomainName | tabl
e _time, host, DomainName | sort - _time
```

الشرح التفصيلي لأسطر استعلام Splunk (SPL Analysis):

أمر SPL	الدور الوظيفي والتحليلي
`index="vpn3" EventCode=3008`	استهداف الفهرس الخاص بسجلات vpn3 وتحديد الحدث رقم 3008 وهو الخاص بطلب ترجمة أسماء النطاقات (DNS Query).
`"..." rex field=_raw`	استخراج اسم النطاق المطلق باستخدام التعبيرات النمطية (Regular Expressions) وتخزينه في الحقل DomainName.
`eval DomainName=lower(...)`	تحويل جميع حروف النطاق إلى حروف صغيرة لتوحيد الصيغة وتسهيل عملية المقارنة والفلترة.
`search NOT DomainName IN (...)`	فلترة واستبعاد حركة المرور الحميدة المعتادة (Whitelist Filter) مثل تحديثات Microsoft وخدمات النظام لتقليل الضوضاء.
`dedup host, DomainName`	حذف السجلات المكررة لكل جهاز ونطاق لإظهار النطاقات الفريدة المزارة فقط لزيادة كفاءة التقرير.
`table & sort`	تنسيق النتائج في جدول يتضمن (الوقت، اسم الجهاز، النطاق) وترتيبها من الأحدث إلى الأقدم.

4. القيمة المضافة للمشروع في بيئة العمل (SOC Impact)

خفوض الضوضاء (Noise Reduction)

استبعاد خدمات نظام ويندوز يتيح لمحلل الـ SOC التركيز على الحركة المشبوهة فقط.

الاستجابة السريعة (Fast Incident Response)

الجمع بين حظر الطرفيات ورصد الـ DNS يقلل من زمن احتواء الخطر (Mean Time to Detect & Respond).